

Informe de Pentesting: Evaluación de Seguridad

Hallazgos, Remediación y Roadmap

Autor: Jefferson Moran



Metodología y Alcance

01

1) Metodología Grey Box

Se combinó conocimiento parcial del entorno con pruebas técnicas.

02

2) Herramientas empleadas

Se utilizó Nmap para reconocimiento de red y enumeración de servicios.

03

3) Objetivo principal

Identificar vulnerabilidades críticas que comprometan confidencialidad, integridad o disponibilidad.

Fase de Reconocimiento: Puertos Detectados

Puerto 21 – FTP (vsftpd 3.0.3)

Severidad: **CRÍTICA**

Puerto 22 – SSH (OpenSSH 9.2p1)

Severidad: **INSEGURO**

Puerto 80 – HTTP (Apache 2.4.62)

Severidad: **RIESGO MEDIO**

Vulnerabilidades Críticas (CVE)

CVE-2024-6387 (RegreSSHion)

Severidad: **CRÍTICA**

RCE crítico en OpenSSH 9.2p1 -
Permite ejecución remota de
código con privilegios de root.

CVE-2024-40725 (Apache
SSRF)

Severidad: **ALTO**

Fallos en manejo de tipos de
contenido - Riesgo de Server-Side
Request Forgery.

Inseguridad FTP

Severidad: **ALTO**

Credenciales en texto plano -
Facilita ataques de sniffing en la
red.

Hallazgos de Configuración

Hemos identificado los siguientes hallazgos críticos de configuración durante el pentesting:

Acceso Anónimo FTP

El servicio permitía login con usuario anonymous sin contraseña.

Credenciales Débiles en BD

Usuario wordpressuser utilizaba contraseña 123456.

Permisos Excesivos

Se encontró permisos 777 en archivo de configuración de PHP.

Enumeración de Directorios Web

Apache permitía listado de archivos en carpetas sin index.html.

Plan de Remediación

01

1) Gestión de Servicios y Puertos

Desactivación de FTP y blindaje SSH modificando PermitRootLogin a no.

03

3) Saneamiento de Permisos

Aplicación del principio de menor privilegio (chmod 600 para wp-config.php, 755/644 para uploads).

02

2) Seguridad de Bases de Datos

Cambio de contraseña por defecto a una más segura.

04

4) Aseguramiento de Apache

Restricción de índices cambiando Options Indexes a Option -Indexes.

Análisis Forense y Persistencia

Se realizó investigación para descartar presencia de backdoors remanentes del incidente de octubre de 2024.

Metodología

Búsquedas recursivas filtrando por fecha de modificación y extensiones críticas (.php, .phtml, .exe, .sh).

Resultado

No se detectaron archivos maliciosos activos. El atacante no logró establecer persistencia mediante scripts en el servidor web, aunque dejó la infraestructura de permisos (777) preparada para futuros ataques.

Roadmap de Seguridad

01

1) Actualización de Software (Patching)

El CVE-2024-6387 en OpenSSH requiere actualización inmediata del paquete openssh-server.

03

3) Monitoreo de Integridad

Implementar herramienta como AIDE o Tripwire para alertas si archivos críticos son modificados sin autorización.

02

2) Detección de Intrusos

Instalar y configurar Fail2Ban para proteger el puerto 22 (SSH) contra ataques de fuerza bruta.

04

4) Copia de Seguridad

Establecer sistema de backups automáticos fuera del servidor (Off-site) antes de actualizaciones mayores.

Conclusiones y Próximos Pasos

La auditoría de seguridad iniciada el 12 de marzo de 2026 revela que el servidor presentaba múltiples configuraciones por defecto extremadamente peligrosas y falta de higiene en la gestión de servicios. Aunque se han mitigado los riesgos más urgentes, se recomienda encarecidamente adoptar las medidas del roadmap a corto plazo.

1) Proceso Evolutivo

La seguridad es un sistema vivo que se adapta y mejora constantemente.

2) Mayor Resiliencia

Adoptar estas recomendaciones fortalecerá la postura de seguridad.

3) Responsabilidad Compartida

La seguridad es responsabilidad de todos.

```
➔ sudo nmap -sV -sC -Pn 192.168.1.16
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-12 19:02 +0100
Nmap scan report for 192.168.1.16
Host is up (0.00036s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
|_ftp-syst:
|_STAT:
|_FTP server status:
|_   Connected to ::ffff:192.168.1.17
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 1
|_   vsFTPd 3.0.3 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh      OpenSSH 9.2p1 Debian 2+deb12u3 (protocol 2.0)
|_ssh-hostkey:
|_   256 aa:f8:39:b3:ce:e6:3a:c9:60:79:bc:6c:06:47:ff:5a (ECDSA)
|_   256 43:ca:a9:c9:31:7b:02:d9:03:ff:40:f2:a3:71:40:03 (ED25519)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
|_http-server-header: Apache/2.4.62 (Debian)
|_http-title: Apache2 Debian Default Page: It works
|_http-robots.txt: 1 disallowed entry
|_/_wp-admin/
MAC Address: 08:00:27:45:83:C1 (Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 9.41 seconds
```

Evidencia: Fase de Reconocimiento

Esta imagen es la captura del informe original que muestra el output del comando "sudo nmap -sV -sC -Pn 192.168.1.16", sirviendo como evidencia del reconocimiento inicial realizado en el sistema.

```
(kali@kali)-[~]  
$ ftp 192.168.1.16  
Connected to 192.168.1.16.  
220 (vsFTPd 3.0.3)  
Name (192.168.1.16:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp>  
ftp> exit
```

Evidencia: Acceso Anónimo FTP

Esta imagen es la captura de pantalla del informe original que demuestra el acceso FTP anónimo exitoso. La captura muestra el terminal con el comando "ftp 192.168.1.16", el login con usuario "anonymous", y el mensaje "230 Login successful", sirviendo como prueba de concepto del hallazgo de acceso anónimo FTP.

```
debian@debian:/var/log$ sudo cat /var/www/html/wp-config.php | grep -E "DB_USER|DB_PASSWORD"
[sudo] password for debian:
define( 'DB_USER', 'wordpressuser' );
define( 'DB_PASSWORD', '123456' );
```

Evidencia: Credenciales Débiles en Base de Datos

Esta imagen es la captura de pantalla del informe original que demuestra el hallazgo de credenciales débiles. La captura debe mostrar el terminal con el comando "sudo cat /var/www/html/wp-config.php | grep -E 'DB_USER|DB_PASSWORD'" y el resultado mostrando "wordpressuser" y "123456", sirviendo como prueba de concepto del hallazgo de credenciales débiles.

```
ls -laR /var/www/html/wp-config.php  
-data www-data 3034 Mar 12 14:48 /var/www/html/wp-c
```

Evidencia: Permisos Excesivos en Archivos

Esta imagen es la captura de pantalla del informe original que demuestra los permisos 777 en archivos de configuración. La captura debe mostrar el terminal con el comando "ls -laR /var/www/html/wp-config.php" y el resultado mostrando "-rwxrwxrwx 1 www-data www-data 3034 Mar 12 14:48 /var/www/html/wp-config.php". Sirve como prueba de concepto del hallazgo de permisos excesivos.

Evidencia: Enumeración de Directorios Web

```
<Directory />
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>

<Directory /usr/share>
    AllowOverride None
    Options Indexes FollowSymLinks
    Require all granted
</Directory>

<Directory /var/www/>
    Options Indexes FollowSymLinks
    AllowOverride None
    Require all granted
</Directory>
```

Esta imagen es la captura de pantalla del informe original que demuestra la enumeración de directorios en Apache. La captura muestra el archivo de configuración de Apache con la sección "<Directory />" mostrando "Options Indexes FollowSymLinks" y "AllowOverride None". Sirve como prueba de concepto del hallazgo de enumeración de directorios.